

# Security Incident Report

|                      |                                                                                                                                                                |
|----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Report ID            | CLD-IR-0002                                                                                                                                                    |
| Related ticket       | CLD-0002 — Reported phishing email impersonating Cloudora HR (payroll theme)                                                                                   |
| Report title         | Payroll-themed credential phishing campaign; two accounts compromised via a lookalike portal                                                                   |
| Analyst              | Adithyan V — SOC Analyst Trainee, MyFirstHack engagement                                                                                                       |
| Date of report (UTC) | 2026-09-13                                                                                                                                                     |
| Incident severity    | P1 — two staff accounts compromised and actively signed into by an external attacker; live credential theft against a company that holds customer payroll data |
| Status               | Contained — eradication verified, monitoring continues                                                                                                         |
| Classification       | CONFIDENTIAL — Internal and client distribution only                                                                                                           |

## 1. Executive summary

On 25 August 2026 an external attacker sent a payroll-themed phishing campaign to 40 Cloudora staff, impersonating Cloudora HR and asking recipients to "confirm their payroll details" on a lookalike website.

The campaign used two message styles: one that forged the real cloudora.io address and failed every authentication check, and one sent from a convincing lookalike domain that passed authentication for that fake domain.

Six employees clicked the link and two entered their passwords. The attacker used both stolen passwords the same day, signing in to those two accounts from an address in Amsterdam.

The compromise was caught the same morning after staff reported the email; both accounts were contained, the attacker's access was cut off, the sending and hosting infrastructure was blocked, and the phishing messages were purged from mailboxes.

A marketing newsletter that one employee reported alongside the phish was confirmed legitimate. No fraudulent payment or data theft was found in the available logs. Four further staff who clicked but did not enter credentials, and thirty who received the email but did not click, are being contacted.

## 2. Incident timeline

All times UTC. Sources: CloudoraMsgTrace\_CL (Exchange Online message trace), CloudoraSignIn\_CL (sign-in logs), and the reported .eml files.

| Time (UTC)          | Source    | Event                                                                                                                                                  |
|---------------------|-----------|--------------------------------------------------------------------------------------------------------------------------------------------------------|
| Aug 25, 06:58       | Msg trace | Legitimate Cloudora newsletter delivered via Mailchimp (later reported, cleared as a false positive)                                                   |
| Aug 25, 08:04–08:20 | Msg trace | Phishing variant A, wave 1, sent from 198.18.44.10 spoofing payroll@cloudora.io; SPF/DKIM/DMARC fail; some copies quarantined by EOP, some delivered   |
| Aug 25, 08:35–08:50 | Msg trace | Variant A wave 2 from 198.18.44.23, and variant B from 198.18.51.7 using lookalike domain cloudora-hr-portal.example (auth passes for the fake domain) |
| Aug 25, 08:39:03    | Msg trace | seth.lane clicks the variant A link; no credentials submitted                                                                                          |
| Aug 25, 08:47:12    | Msg trace | freya.lynn clicks variant A and SUBMITS credentials                                                                                                    |
| Aug 25, 09:05:44    | Msg trace | ryan.boyd clicks variant B and SUBMITS credentials                                                                                                     |

| Time (UTC)                    | Source    | Event                                                                                                                                                             |
|-------------------------------|-----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Aug 25, 09:11                 | Ticket    | james.holt forwards the phish to the SOC; ticket CLD-0002 raised, investigation starts                                                                            |
| Aug 25, 09:58 / 10:12 / 11:47 | Msg trace | hugo.marsh, chloe.price and dina.said click the link; none submit credentials                                                                                     |
| Aug 25, 10:34:20              | Sign-in   | Attacker signs in as freya.lynn from 198.18.7.200 (Amsterdam, NL) on Windows 11 / Chrome — harvested credential used (T1078); Outlook Web 10:36, SharePoint 10:41 |
| Aug 25, 13:22:05              | Sign-in   | Attacker signs in as ryan.boyd from 198.18.7.200 (Amsterdam) — second account used; Outlook Web 13:25                                                             |
| Aug 25, ~14:00                | Response  | Containment executed on both accounts (see section 7)                                                                                                             |

### 3. Findings

#### Finding 1 — A payroll-themed phishing campaign was delivered to staff

On 25 August, 40 Cloudora mailboxes were targeted by a phishing campaign with the subject lines "Payroll update: action required before 5pm" and "Action required: confirm your August payroll details", both impersonating Cloudora HR and linking to cloudora-hr-portal.example, a lookalike of cloudora.io. Exchange Online Protection quarantined every copy sent to 4 recipients; 36 recipients had at least one copy delivered to the inbox. Evidence: CloudoraMsgTrace\_CL delivery events, and the reported .eml files.

#### Finding 2 — The campaign used two authentication tactics; passing auth did not mean safe

Variant A forged the real address payroll@cloudora.io and failed SPF, DKIM and DMARC (compauth=fail), sent from 198.18.44.10 and 198.18.44.23. Variant B was sent from the attacker's own lookalike domain cloudora-hr-portal.example (198.18.51.7) and PASSED SPF, DKIM and DMARC — but for the lookalike domain, not for Cloudora. Authentication only proves the sending domain, not its legitimacy; both variants are malicious. This is the same test that clears the false positive in Finding 6.

#### Finding 3 — Two accounts submitted credentials and were compromised

freya.lynn@cloudora.io and ryan.boyd@cloudora.io both clicked and submitted credentials (CloudoraMsgTrace\_CL click events at 08:47 and 09:05, CredentialsSubmitted = Yes). Both were then signed into from 198.18.7.200 (Amsterdam, Netherlands) on a Windows 11 / Chrome device never seen on their accounts: Freya at 10:34 (impossible travel against her genuine Manchester sign-ins that morning), Ryan at 13:22. The attacker accessed Outlook Web and, for Freya, SharePoint Online. This is use of harvested valid credentials (T1078).

#### Finding 4 — Four further staff clicked the link but did not submit credentials

seth.lane, chloe.price, hugo.marsh and dina.said clicked the phishing link (CredentialsSubmitted = No) and show no anomalous sign-in in the logs. They are not confirmed compromised, but a click means they reached the harvesting page; they are treated as elevated risk pending a precautionary password reset and a direct check-in.

#### Finding 5 — Thirty staff received the phish but did not click; four were protected by EOP

Thirty delivered-to recipients did not click and form the near-miss list for user communications. A further four (emma.hayes, maya.chen, nina.cole, ruth.dean) were targeted but had every copy quarantined by Exchange Online Protection, so never saw the message. Sorting every affected account into one tier is what keeps the response proportionate.

#### Finding 6 — The reported Mailchimp newsletter is legitimate (false positive, cleared)

The "Cloudora Monthly" newsletter forwarded by adam.clark was sent for Cloudora via Mailchimp. It passes SPF, is DKIM-signed and aligned to cloudora.io, passes DMARC, carries a valid one-click List-Unsubscribe, and links only to Cloudora's real list-manage domain. Unlike variant B, its authentication aligns to the genuine cloudora.io brand. Verdict: legitimate marketing mail, not part of the attack. Cleared with evidence so it is not re-investigated.

## 4. Indicators of compromise (IOCs)

| Type    | Value                                                | First seen (UTC) | Context                                                                                       |
|---------|------------------------------------------------------|------------------|-----------------------------------------------------------------------------------------------|
| Domain  | cloudora-hr-portal.example                           | Aug 25           | Lookalike of cloudora.io; phishing / credential harvesting; subdomains mail., mailer., login. |
| URL     | hxxps://cloudora-hr-portal[.]example/payroll/login   | Aug 25, 08:04    | Variant A harvesting link (defanged)                                                          |
| URL     | hxxps://login.cloudora-hr-portal[.]example/verify    | Aug 25, 08:35    | Variant B harvesting link (defanged)                                                          |
| IPv4    | 198.18.44.10                                         | Aug 25, 08:04    | Variant A wave-1 sending relay + harvest host (Amsterdam, synthetic)                          |
| IPv4    | 198.18.44.23                                         | Aug 25, 08:35    | Variant A wave-2 sending relay (same /24)                                                     |
| IPv4    | 198.18.51.7                                          | Aug 25, 08:35    | Variant B sending relay                                                                       |
| IPv4    | 198.18.7.200                                         | Aug 25, 10:34    | Attacker sign-in IP (Amsterdam) — harvested credential use; blocked                           |
| Sender  | payroll@cloudora.io (spoofed)                        | Aug 25, 08:04    | Forged From on variant A; Reply-To hr-support@cloudora-hr-portal.example                      |
| Sender  | payroll@cloudora-hr-portal.example                   | Aug 25, 08:35    | Variant B From (lookalike domain)                                                             |
| Subject | Payroll update: action required before 5pm           | Aug 25, 08:04    | Variant A                                                                                     |
| Subject | Action required: confirm your August payroll details | Aug 25, 08:35    | Variant B                                                                                     |

## 5. MITRE ATT&CK mapping

| Tactic            | Technique ID | Technique name                               | Evidenced by                                            |
|-------------------|--------------|----------------------------------------------|---------------------------------------------------------|
| Initial Access    | T1566.002    | Phishing: Spearphishing Link                 | Findings 1–2, the two phishing variants and their links |
| Credential Access | T1598.003    | Phishing for Information: Spearphishing Link | The credential-harvesting page behind the link          |
| Initial Access    | T1078.004    | Valid Accounts: Cloud Accounts               | Finding 3, attacker sign-ins with harvested credentials |

*Context technique (infrastructure): the attacker registered and hosted a lookalike domain (T1583.001, Acquire Infrastructure: Domains). Mapped for awareness; not directly evidenced in these logs beyond the domain itself.*

## 6. Scope

### Accounts confirmed compromised (2)

freya.lynn@cloudora.io (attacker sign-in 10:34:20 UTC) and ryan.boyd@cloudora.io (13:22:05 UTC), both 25 Aug, both from 198.18.7.200; both submitted credentials to the phishing page.

### Accounts clicked but not confirmed compromised (4)

seth.lane, chloe.price, hugo.marsh, dina.said — clicked the link, no credentials submitted, no anomalous sign-in. Precautionary reset and direct check-in.

### Accounts targeted but not compromised (34)

Thirty received the phish and did not click (near-miss, user comms). Four more (emma.hayes, maya.chen, nina.cole, ruth.dean) had every copy quarantined by EOP.

Emails investigated and cleared (1)

The "Cloudora Monthly" Mailchimp newsletter — legitimate marketing mail (Finding 6).

7. Actions taken

Executed afternoon of 25 Aug (UTC), in order.

| Order | Action                                                                                                                                                      | Performed by     | Verified how                                          |
|-------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------|-------------------------------------------------------|
| 1     | Revoked all active sessions and refresh tokens for freya.lynn and ryan.boyd                                                                                 | Adithyan V (SOC) | Confirmed via session/token revocation log entries    |
| 2     | Reset credentials for both compromised accounts                                                                                                             | Adithyan V (SOC) | Password change events confirmed in identity logs     |
| 3     | Required and re-registered MFA on both accounts                                                                                                             | Adithyan V (SOC) | MFA re-registration confirmed in identity logs        |
| 4     | Blocked infrastructure: 198.18.44.10, 198.18.44.23, 198.18.51.7, 198.18.7.200 and cloudora-hr-portal.example (all subdomains) at mail gateway and web proxy | Adithyan V (SOC) | Block rules confirmed active on gateway/proxy         |
| 5     | Purged delivered phishing messages from all mailboxes (soft delete / ZAP)                                                                                   | Adithyan V (SOC) | Purge job completion confirmed against mailbox search |
| 6     | Re-ran the victim sign-in and attacker-IP pivot queries                                                                                                     | Adithyan V (SOC) | No 198.18.7.200 activity found after containment      |

8. Recommendations

- Precautionary password resets and a direct check-in for the four clicked-but-no-credential staff; user communications and awareness for the thirty near-miss recipients.
- Enforce MFA on all accounts and disable legacy authentication that bypasses it; both compromises were password-only.
- Move cloudora.io DMARC policy to p=reject so spoofing variants like variant A are rejected outright, not merely quarantined, and downstream recipients reject them too.
- Add mail-gateway detection for newly-registered lookalike domains and for external mail whose From is cloudora.io but which fails DMARC.
- Deploy a sign-in detection rule for a successful sign-in from a new country within a few hours of a phishing-link click. This would have flagged both compromises the same morning.
- Block the phishing infrastructure permanently and monitor for the actor re-registering adjacent lookalike domains.

9. Lessons learned

Staff reporting caught this: the first forwarded email opened the ticket before automated detection did, which argues for keeping the report button prominent and praised.

The message trace turned a single reported email into full campaign scope in minutes, and pivoting on the attacker sign-in IP surfaced the second victim immediately — never stop at victim one.

The false positive mattered as much as the phish: variant B and the Mailchimp newsletter both pass authentication, and only checking which domain they pass for tells them apart.

The gap to close is detection speed: both compromises were visible in the logs within an hour of the clicks, and a click-then-foreign-login rule would have alerted automatically rather than waiting on a human report.

---

*End of report CLD-IR-0002. Training artefact — Cloudora is a fictional company; all data is synthetic. MyFirstHack | myfirstcyberjob community resource.*